UNIVERSIDAD INTERAMERICANA DE PUERTO RICO · RECINTO DE FAJARDO

PROYECTO FINAL · DESARROLLO WEB FULL-STACK

Sabías que PR

Documentación técnica

Estructura del proyecto · rutas API y endpoints · configuración del entorno · autenticación · dependencias

Estudiante	William Collado
Curso	COMP2053 — Desarrollo Web Full-Stack
Profesora	Milagros Donato Cintrón
Institución	Universidad Interamericana de Puerto Rico, Recinto de Fajardo
Fecha	20 de octubre de 2026

Documento generado automáticamente a partir del código (`backend/scripts/generar-doc-tecnica.js`) para la parte 4 de la entrega: estructura del proyecto, rutas API, endpoints, configuración del entorno, autenticación y dependencias. Se vuelve a generar con `node backend/scripts/generar-doc-tecnica.js`.

1. Estructura del proyecto

Estructura del repositorio (la pide el PDF de la rúbrica):

```
/frontend   sitio estático: páginas HTML generadas por build.js, scripts JS, CSS, imágenes, i18n, service worker
/backend    API REST (Node.js + Express): src/routes, src/middleware, src/validators, src/services, sql/, scripts/
README.md   descripción, requisitos, instalación, ejecución y estructura
docs/       documentación, PDFs y guiones
```

2. Rutas API y endpoints

La API es REST, responde JSON y está publicada en `https://sabiasquepr-backend-uufz.onrender.com`. **Acceso:** *Público* = sin sesión; *Opcional* = funciona con o sin sesión; *Sesión* = requiere un JWT válido; *Moderador/Admin* y *Admin* = además exigen ese rol guardado en la tabla `perfiles`.

Método	Ruta	Acceso	Módulo
POST	`/api/stripe/webhook`	Firma de Stripe (sin sesión)	stripeWebhook.js
GET	`/api/foro/posts`	Público	foro.js
GET	`/api/foro/posts/:id`	Público	foro.js
POST	`/api/foro/posts`	Sesión	foro.js
PATCH	`/api/foro/posts/:id`	Sesión	foro.js
DELETE	`/api/foro/posts/:id`	Sesión	foro.js
POST	`/api/foro/posts/:postId/comentarios`	Sesión	foro.js
DELETE	`/api/foro/comentarios/:id`	Sesión	foro.js
GET	`/api/noticias`	Opcional	noticias.js
GET	`/api/noticias/:id`	Opcional	noticias.js
POST	`/api/noticias`	Admin	noticias.js
PUT	`/api/noticias/:id`	Admin	noticias.js
DELETE	`/api/noticias/:id`	Admin	noticias.js
GET	`/api/contenidos`	Opcional	contenidos.js
GET	`/api/contenidos/:id`	Opcional	contenidos.js
POST	`/api/contenidos`	Admin	contenidos.js
PUT	`/api/contenidos/:id`	Admin	contenidos.js
DELETE	`/api/contenidos/:id`	Admin	contenidos.js
GET	`/api/productos`	Público	productos.js
GET	`/api/productos/:id`	Público	productos.js

Método	Ruta	Acceso	Módulo
POST	`/api/productos`	Admin	productos.js
PUT	`/api/productos/:id`	Admin	productos.js
DELETE	`/api/productos/:id`	Admin	productos.js
POST	`/api/stripe/create-checkout-session`	Sesión	stripe.js
POST	`/api/stripe/create-checkout-session-tienda`	Sesión	stripe.js
GET	`/api/admin/estado-seguridad`	Moderador/Admin	admin.js
POST	`/api/admin/autocompletar-ia`	Admin	admin.js
POST	`/api/admin/investigar`	Admin	admin.js
POST	`/api/admin/redactar`	Admin	admin.js
GET	`/api/admin/uso-ia`	Moderador/Admin	admin.js
GET	`/api/admin/traducciones/:tipo/:id`	Admin	admin.js
PUT	`/api/admin/traducciones/:tipo/:id/:idioma`	Admin	admin.js
DELETE	`/api/admin/traducciones/:tipo/:id/:idioma`	Admin	admin.js
POST	`/api/admin/traducir`	Admin	admin.js
GET	`/api/admin/gastos`	Admin	admin.js
POST	`/api/admin/gastos`	Admin	admin.js
PUT	`/api/admin/gastos/:id`	Admin	admin.js
DELETE	`/api/admin/gastos/:id`	Admin	admin.js
PUT	`/api/perfil`	Sesión	perfil.js
POST	`/api/perfil/fecha-nacimiento`	Sesión	perfil.js
GET	`/api/perfil/agradecimiento`	Sesión	perfil.js
PUT	`/api/perfil/agradecimiento`	Sesión	perfil.js
DELETE	`/api/perfil/agradecimiento`	Sesión	perfil.js
POST	`/api/perfil/confirmar-edad`	Sesión	perfil.js
POST	`/api/perfil/confirmar-terminos-logica-humana`	Sesión	perfil.js
GET	`/api/agradecimientos`	Público	agradecimientos.js
GET	`/api/ordenes`	Sesión	ordenes.js
GET	`/api/comentarios`	Público	comentarios.js
POST	`/api/comentarios`	Sesión	comentarios.js
DELETE	`/api/comentarios/:id`	Sesión	comentarios.js
POST	`/api/reportes`	Sesión	reportes.js
GET	`/api/reportes`	Moderador/Admin	reportes.js
PATCH	`/api/reportes/:id`	Moderador/Admin	reportes.js
POST	`/api/newsletter/subscribe`	Público	newsletter.js

Total: 54 endpoints (Firma de Stripe (sin sesión): 1, Público: 7, Sesión: 18, Opcional: 4, Admin: 20, Moderador/Admin: 4). Además existe `GET /api/health`.

3. Configuración del entorno

Variables de entorno del backend (solo nombres; los valores nunca van en el repositorio, ver `backend/.env.example`):

Variable	Para qué sirve
`DATABASE_URL`	Conexión a PostgreSQL (Supabase, pooler de sesión)
`PORT`	Puerto de la API
`SUPABASE_URL`	Dirección del proyecto Supabase; de ahí salen las llaves públicas (JWKS) para verificar el JWT
`FRONTEND_ORIGIN`	Orígenes permitidos por CORS (separados por coma)
`STRIPE_SECRET_KEY`	Llave secreta de Stripe (modo de prueba)
`STRIPE_WEBHOOK_SECRET`	Secreto para verificar la firma del webhook de Stripe
`STRIPE_PREMIUM_PRICE_ID`	Precio del apoyo mensual en Stripe
`TURNSTILE_SECRET_KEY`	Verificación anti-robots (Cloudflare Turnstile)
`ANTHROPIC_API_KEY`	API de Claude para los agentes del panel de administración
`BEEHIIV_API_KEY`, `BEEHIIV_PUBLICATION_ID`	Alta de suscriptores al boletín (Beehiiv)

Comandos (dentro de `backend/`): `npm install`, `npm run dev` (desarrollo), `npm start`, `npm run db:schema` (crear las tablas), `npm test` y `npm run test:coverage`.

4. Autenticación y autorización

- **Registro e inicio de sesión:** Supabase Auth (correo y contraseña, y Google). El panel de administración exige además verificación en dos pasos (TOTP).
- **JWT:** el navegador envía `Authorization: Bearer <token>`. El backend lo **verifica en el servidor** con la librería `jose` contra las llaves públicas de Supabase (JWKS, algoritmo ES256); no confía en nada que venga del cliente. Un token falso o vencido devuelve 401.
- **Roles:** guardados en la tabla `perfiles` (`usuario`, `premium`, `moderador`, `admin`). Los middlewares `requireAuth`, `requireAdmin` y `requireModerador` protegen cada ruta.
- **Otras medidas:** límite de peticiones por IP, `helmet`, cabeceras CSP en el frontend, validación centralizada de datos (`src/validators`), mensajes de error genéricos y comprobación de contraseñas filtradas.

5. Dependencias

Backend:

Paquete	Uso
express	Servidor y rutas de la API
pg	Cliente de PostgreSQL
jose	Verificación del JWT (JWKS)
cors	CORS
helmet	Cabeceras de seguridad
express-rate-limit	Límite de peticiones
stripe	Pagos y webhook
dotenv	Variables de entorno
@mozilla/readability + jsdom	Extraer el texto de artículos (agentes del panel)
jest + supertest	Pruebas automáticas (solo desarrollo)

Frontend: HTML5, CSS3 y JavaScript sin framework; cliente `supabase-js` incluido localmente (`vendor/`).